

IT labs



MySQL Database Misconfiguration and Exploitation Lab Writeup

April 20, 2026

Written by: Alexander M. Sapo

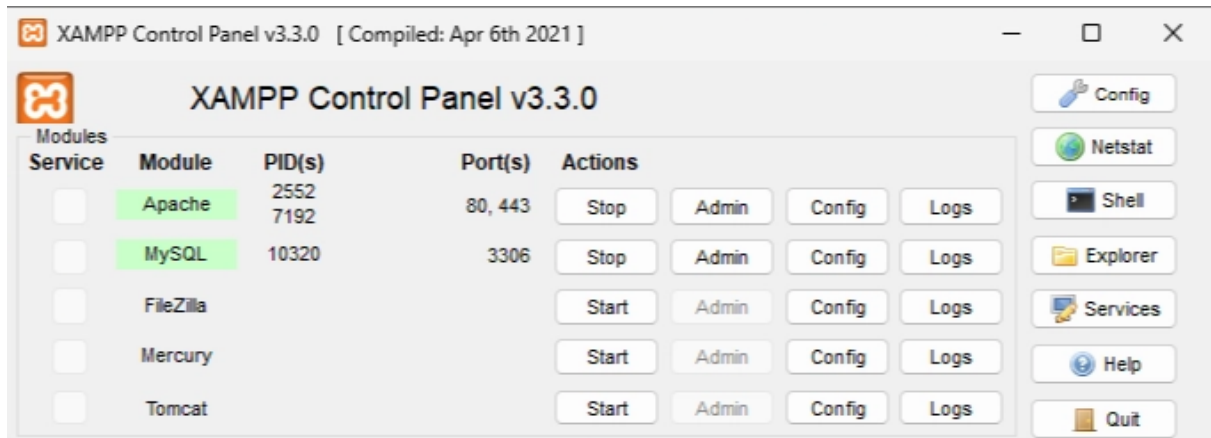
Information Management Fundamentals

Objective

This report documents a local network MySQL service configuration, its exposure during reconnaissance, and the resulting exploitation due to weak authentication and misconfigured privileges. The assessment demonstrates how common database misconfigurations can lead to unauthorized access and potential data compromise.

Environment Overview

- Database Service: MySQL (via XAMPP)
- Web Service: Apache (enabled on same host)
- Target IP Address: 10.0.0.188
- Database Port: 3306/TCP
- Network Scope: Local subnet (10.0.0.0/24)



Database User Creation and Privilege Configuration

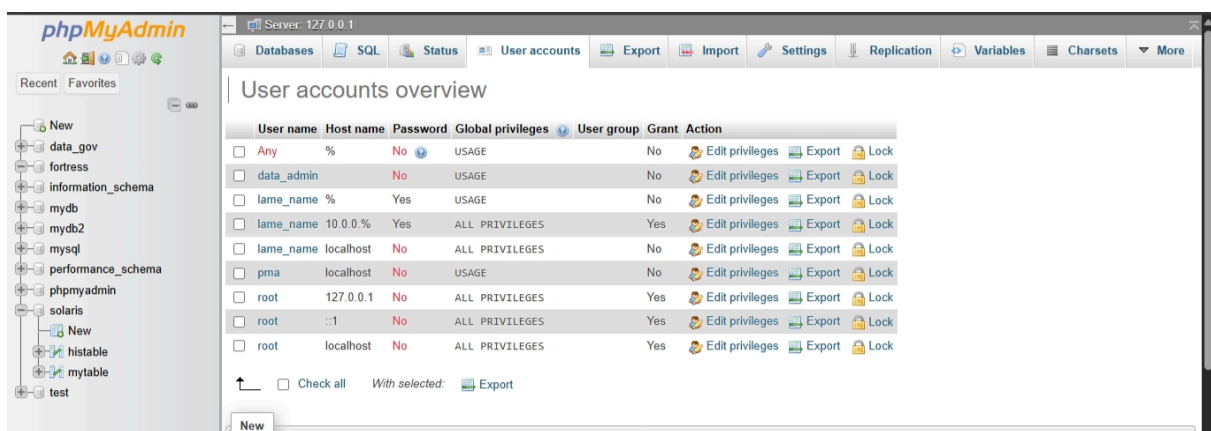
A new MySQL user was created with network-restricted access:

```
CREATE USER 'user_name'@'10.0.0.%' IDENTIFIED BY 'password';
```

Privileges were assigned to the user as follows:

```
GRANT ALL PRIVILEGES ON *.* TO 'user_name'@'10.0.0.%';
GRANT SELECT, INSERT, UPDATE, DELETE ON *.* TO 'user_name'@'10.0.0.%';
FLUSH PRIVILEGES;
```

Although the user was intended to operate within a restricted subnet, granting **ALL PRIVILEGES** on all databases effectively overrides granular permission control. This results in full administrative access across the database server.



Service Exposure and Reconnaissance

A network scan was conducted from a Linux host using Nmap:

```
nmap 10.0.0.188 -p3306 -sV -Pn --disable-arp-ping --min-rate=50 -T4
```

```
root@SolarisFortress:~/home/loki# nmap 10.0.0.188 -p3306 -sV -Pn --disable-arp-ping --min-rate=50 -T4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-20 14:20 +0800
Nmap scan report for 10.0.0.188
Host is up (0.0014s latency)
PORT      STATE SERVICE
3306/tcp   open  mysql
MAC Address: 40:00:80:06:F4:7B (Unknown)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.04 seconds
```

The scan confirmed that port 3306 (MySQL) was open and accessible externally within the local network.

This indicates that:

- The MySQL service is exposed on a network interface
- No effective firewall rules are restricting access to the database port

Exposing database services directly to a network significantly increases the attack surface, particularly when authentication controls are weak or misconfigured.

A remote connection attempt was made to the MySQL service:

```
mysql -u lame_name -p -h 10.0.0.188 --skip-ssl
```

```
root@SolarisFortress: /home/loki
Session Actions Edit View Help
loki@SolarisFortress:~$ mysql -u lame_name -p -h 10.0.0.188 --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 97
Server version: 10.4.32-MariaDB mariadb.org binary distribution
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.
MariaDB [(none)]>
```

During the connection process, SSL/TLS was not available or not properly configured on the server. As a result, SSL negotiation failed, and the connection was established without encryption using the `--skip-ssl` option.

```
root@SolarisFortress: /home/loki
mysql -u lame_name -p -h 10.0.0.188
Enter password:
ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it
root@SolarisFortress: /home/loki
```

Authentication was successful using weak credentials:

```
Password: admin123
```

In this scenario, it is assumed that a common username was identified. In real-world attack scenarios, database credentials, particularly usernames, are often exposed due to misconfigurations. Attackers commonly exploit MySQL services that are directly accessible over network interfaces or lack enforced SSL/TLS encryption, enabling the interception of sensitive data. These risks are further amplified when weak authentication credentials are used, making the system highly vulnerable to brute-force attacks, which in turn enables attackers to modify or exfiltrate data from the database. This highlights the critical importance of carefully implementing and maintaining proper security measures, such as enforcing strict access controls, whitelisting only authorized users, properly configuring firewall rules, and ensuring the use of strong passwords.